# Informe de pruebas de vulnerabilidad

GPSMapApp (com.example.myapplication)

| | |
|---|---|
| Proyecto | GPSMapApp (SimpleGPSMapApp), Android en Java con Google Maps |
| Archivo analizado | app-debug.apk, 15.0 MB, versión 1.0 (código 1) |
| MD5 | e30c4522da3ffc45e2f70f896216ba84 |
| SDK | minSdk 30 / targetSdk 30 |
| Herramienta | MobSF v4.6.3 (análisis estático y dinámico con Frida) |
| Entorno | Emulador Pixel 5 (sdk_gphone_x86), Android 11 (API 30), vía ADB; MobSF en Docker |
| Fechas | 28 y 29 de octubre de 2026 |
| Actividad | 2.5 Manejo de elementos de seguridad, Programación Android |

**Alcance:** este informe documenta los procedimientos, resultados, evidencias y limitaciones de las pruebas realizadas con MobSF, y propone correcciones. Complementa a *vulnerabilities.md* y *best_practices.md*.

# 1. Resumen ejecutivo

Se analizó el APK de depuración de GPSMapApp con MobSF. Se confirmaron **5 hallazgos**: 2 de severidad alta y 3 de severidad media. No se observaron datos sensibles ni conexiones inseguras confirmadas durante la ejecución, pero varias pruebas quedaron incompletas (sección 6), por lo que **no se puede concluir que la aplicación esté libre de vulnerabilidades**.

| Severidad | Cantidad | Hallazgos |
|---|---|---|
| Crítica | 0 | - |
| Alta | 2 | V-01 certificado debug, V-02 debuggable |
| Media | 3 | V-03 allowBackup, V-04 receiver exportado, V-05 clave de Maps |
| Baja | 0 | - |
| Informativa | 5 | Observaciones O-01 a O-05 |

MobSF asignó **66/100 (LOW RISK, grado A)** al escaneo del 29/10/2026. Un escaneo previo del 28/10/2026 (MobSF v4.6.2) mostró 45/100 con la misma lista de hallazgos; se toma el segundo como resultado oficial. La puntuación es un indicador automático y no equivale a una garantía de seguridad.

**Nota:** el APK es una compilación debug. Los hallazgos V-01 y V-02 son esperables en ese tipo de compilación; su riesgo real depende del APK que se publique. Se recomienda repetir el análisis con el APK release.

# 2. Metodología y procedimiento

• **Análisis estático:** se cargó *app-debug.apk* en MobSF (Static Analyzer). Se revisaron certificado, manifiesto, permisos, componentes, secretos, código (SAST), APKiD y SBOM.

• **Análisis dinámico:** MobSF se conectó al emulador Android 11 por ADB. Instaló una versión del APK con Frida Gadget y el certificado raíz de MobSF, y se inició la instrumentación (*Spawn & Inject*).

• **Scripts de Frida activos:** API Monitoring, SSL Pinning Bypass, Root Detection Bypass, Debugger Check Bypass y Clipboard Monitor.

• **Interacción:** se abrió la app, se cargó el mapa y se agregaron marcadores (por ejemplo, "Punto #3"), mientras se registraba la actividad en Live API Monitor y Logcat.

• **Informes generados:** Static Analysis (PDF), Android Static Analysis Report y Dynamic Analysis (49 páginas).

• **Herramientas no usadas:** OWASP ZAP y SonarQube.

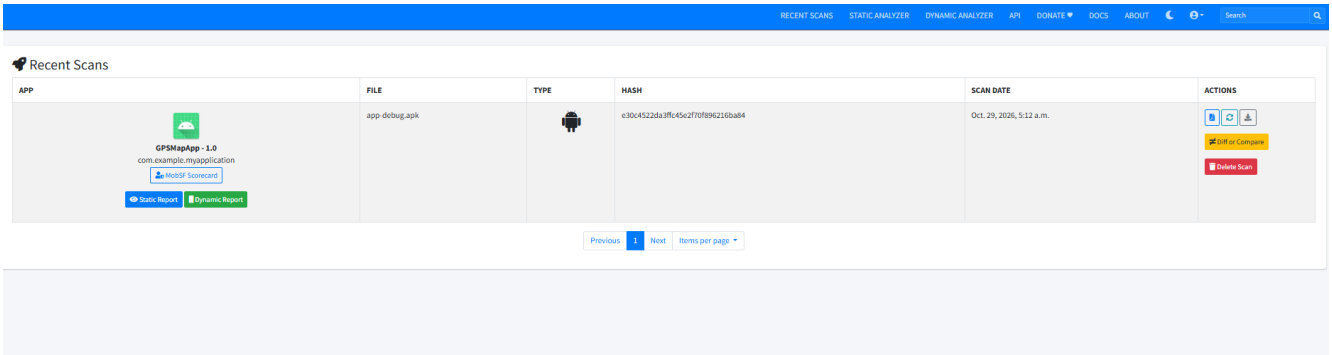



Figura 1. Escaneo registrado en MobSF (app-debug.apk, 29/10/2026)

# 3. Resultados del análisis estático

| ID | Hallazgo | Severidad | Evidencia |
|---|---|---|---|
| V-01 | App firmada con certificado de depuración (CN=Android Debug) | Alta | Certificate Analysis |
| V-02 | Depuración habilitada (android:debuggable=true) | Alta | Manifest Analysis 1; Fig. 2 línea 17 |
| V-03 | Copia de seguridad permitida (android:allowBackup=true) | Media (warning) | Manifest Analysis 2; Fig. 2 línea 17 |
| V-04 | Receiver exportado ProfileInstallReceiver con permiso DUMP | Media (warning) | Manifest Analysis 3; Fig. 2 líneas 33-46 |
| V-05 | Clave de API de Google Maps en el APK | Media (evaluación propia) | Possible Hardcoded Secrets |

**Categorías revisadas sin hallazgos** (solo describen lo que MobSF reportó): Network Security, Code Analysis, Browsable Activities, Shared Library Binary Analysis, Firebase Database Analysis y Trackers (0/432). Componentes exportados: 0/2 activities, 0/0 services, 1/1 receivers, 0/1 providers.

**Permisos:** INTERNET, ACCESS_FINE_LOCATION, ACCESS_COARSE_LOCATION, CAMERA, ACCESS_NETWORK_STATE y un permiso propio de AndroidX. Se debe verificar si la app usa CAMERA; si no, eliminarlo.

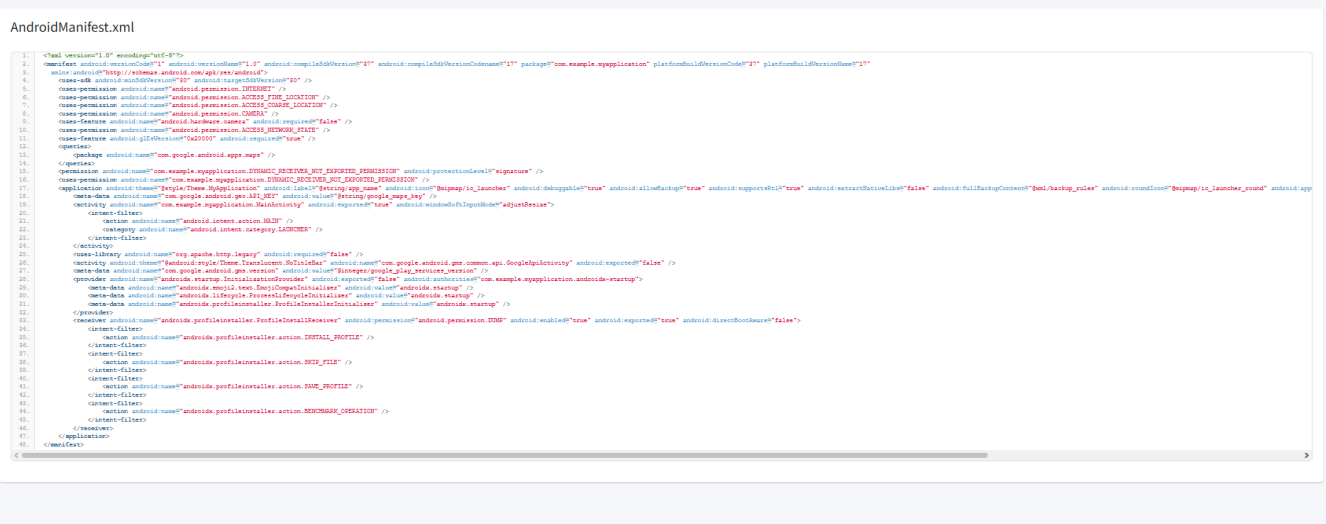



Figura 2. AndroidManifest.xml mostrado por MobSF (debuggable, allowBackup, receiver exportado)

# 4. Registro detallado de vulnerabilidades

## V-01: Aplicación firmada con certificado de depuración

| | |
|---|---|
| Severidad | Alta (MobSF) |
| Origen | Análisis estático |
| Descripción | El APK está firmado con el certificado CN=Android Debug, O=Android, C=US. MobSF indica que una app de producción no debe distribuirse con él. |
| Impacto potencial | Cualquier instalación de Android Studio genera ese keystore; un tercero podría firmar una versión alterada. Google Play no acepta APK firmados con él. |
| Pasos para reproducir | MobSF, Static Analyzer, sección Certificate Analysis. |
| Recomendación | Firmar la versión release con un keystore propio guardado fuera del repositorio (ver best_practices.md, práctica 1). |
| Estado | Pendiente |

## V-02: Depuración habilitada (android:debuggable=true)

| | |
|---|---|
| Severidad | Alta (MobSF) |
| Origen | Análisis estático |
| Descripción | El manifiesto declara android:debuggable="true" en <application>. |
| Impacto potencial | Permite acoplar un depurador, volcar trazas y acceder a clases auxiliares, facilitando la ingeniería inversa. |
| Pasos para reproducir | MobSF, Manifest Analysis, hallazgo 1; línea 17 del manifiesto (Figura 2). |
| Recomendación | Publicar solo compilaciones release (debuggable en false por defecto). |
| Estado | Pendiente de verificación en el APK release |

## V-03: Copia de seguridad permitida (android:allowBackup=true)

| | |
|---|---|
| Severidad | Media (MobSF: warning) |
| Origen | Análisis estático |
| Descripción | La app permite respaldar sus datos mediante ADB. El manifiesto referencia además @xml/backup_rules. |
| Impacto potencial | Con depuración USB activa, se podrían copiar datos de la app fuera del dispositivo; el riesgo crece si se guardan datos sensibles. |
| Pasos para reproducir | MobSF, Manifest Analysis, hallazgo 2. |
| Recomendación | android:allowBackup="false", o excluir archivos sensibles en backup_rules.xml. |
| Estado | Pendiente |

## V-04: Receiver exportado ProfileInstallReceiver

| | |
|---|---|
| Severidad | Media según MobSF. Evaluación propia: baja |
| Origen | Análisis estático |
| Descripción | androidx.profileinstaller.ProfileInstallReceiver está exportado y protegido por android.permission.DUMP, que no se define en la app. MobSF indica revisar su nivel de protección. |
| Impacto potencial | Si el permiso fuera normal o dangerous, otra app podría interactuar con el receiver. En Android, DUMP es de nivel signature\|privileged, por lo que el riesgo es bajo. El componente lo agrega AndroidX. |
| Pasos para reproducir | MobSF, Manifest Analysis, hallazgo 3; líneas 33-46 del manifiesto. |
| Recomendación | Mantener profileinstaller actualizado; si no se usan perfiles de línea base, eliminar el receiver con tools:node="remove". Documentar el riesgo aceptado. |
| Estado | Pendiente de verificación |

## V-05: Clave de API de Google Maps incluida en el APK

| | |
|---|---|
| Severidad | Media (evaluación propia; MobSF la lista sin severidad) |
| Origen | Análisis estático |
| Descripción | MobSF detectó google_maps_key (valor AIzaSyCq4J...ZiNsc, enmascarado). El manifiesto la referencia en meta-data com.google.android.geo.API_KEY. |
| Impacto potencial | Puede extraerse del APK. Sin restricciones, un tercero podría consumir la cuota o generar costos en la cuenta de Google Cloud. |
| Pasos para reproducir | MobSF, Possible Hardcoded Secrets. |
| Recomendación | Restringir la clave por paquete + huella SHA-1 y a Maps SDK for Android; inyectarla desde local.properties; rotarla si ya se publicó. |
| Estado | Pendiente |

# 5. Resultados del análisis dinámico

Observaciones registradas:

• MobSF informó que el entorno estaba listo para análisis dinámico, con streaming de pantalla y Logcat iniciados (Figura 3).

• Se cargaron los scripts de Frida api_monitor, ssl_pinning_bypass, root_bypass, debugger_check_bypass y dump_clipboard (Figura 4).

• El script de SSL pinning no encontró bibliotecas de pinning comunes (OkHttp CertificatePinner, TrustKit, Cronet, etc.) y registró dos veces *checkTrustedRecursive() bypassed*.

• MobSF avisó que la sesión usa un APK modificado (Frida Gadget, CA raíz de MobSF, pins XML de seguridad de red eliminados).

Estas observaciones describen el comportamiento de las herramientas; por sí solas no demuestran una vulnerabilidad explotable. Que un script haya "bypassed" una comprobación no prueba que la app tenga o no pinning.

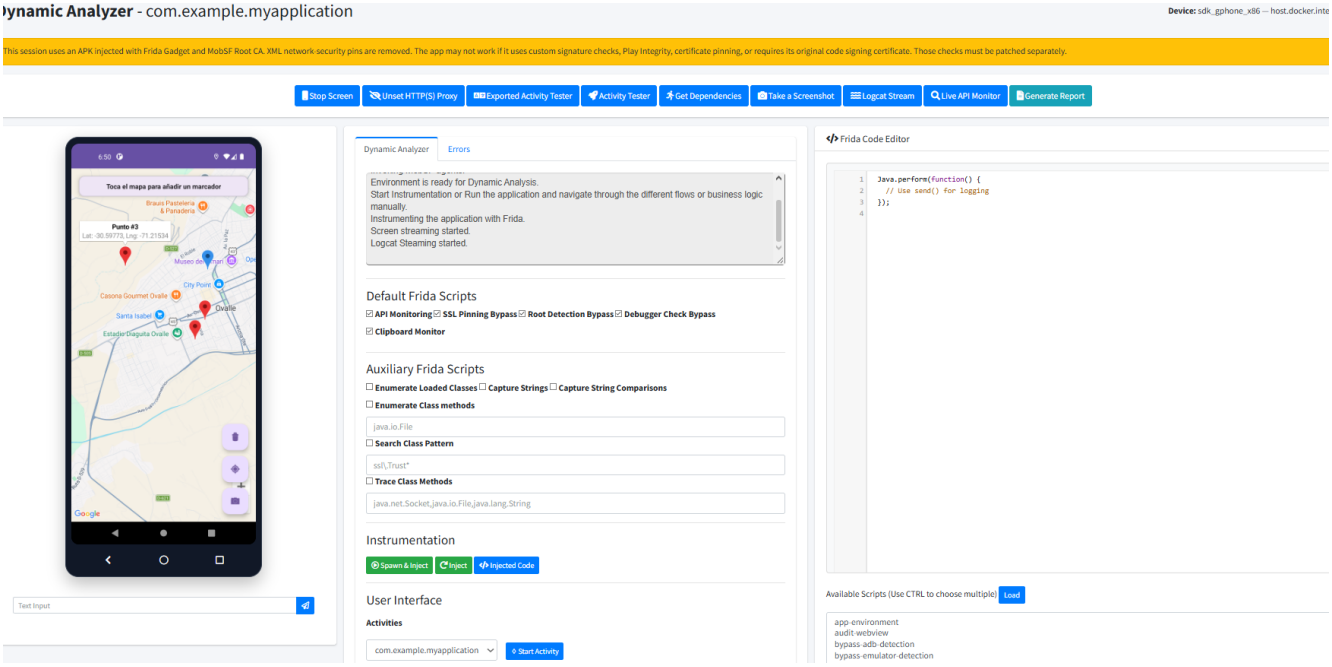



Figura 3. Dynamic Analyzer: entorno listo, scripts por defecto activos y app en ejecución




Figura 4. Frida Logs: scripts cargados y resultado del SSL Pinning Bypass

## Resultados del monitoreo de API

| Aspecto | Resultado |
|---|---|
| Solicitudes observadas | Casi todo HTTPS hacia servicios de Google (mt0.google.com, csi.gstatic.com, clients4.google.com/glm/mmap/api, dl.google.com, redirector.gvt1.com, www.google.com/generate_204). Dos URL HTTP: connectivitycheck.gstatic.com/generate_204 (comprobación de conectividad de Android) y goo.gl/8rd3yj (enlace de documentación de librerías de Google). No se confirmó que la app enviara datos por ellas. |
| Datos sensibles observados | Ninguna credencial ni dato personal en los registros revisados. Actividad de las librerías de Google: consultas a ContentResolver por maps_client_id, país de la SIM, hashes MessageDigest del nombre del paquete y archivos DATA_disk_creation_time_* creados con openFileOutput en modo privado. |
| Problemas identificados | Ninguno confirmado. Base64.decode, registerReceiver (BATTERY_CHANGED) y las 9.662 consultas a ContentResolver provienen de Google Play Services y del SDK de Maps. El DexClassLoader que carga un .dex desde cache/ es el agente de Frida. |
| Portapapeles | Clipboard Dump no registró contenido. |
| TLS/SSL Security Tester | Los 4 tests figuran como Not Tested (Cleartext, TLS Misconfiguration, Pinning/CT Bypass, Pinning/CT). |

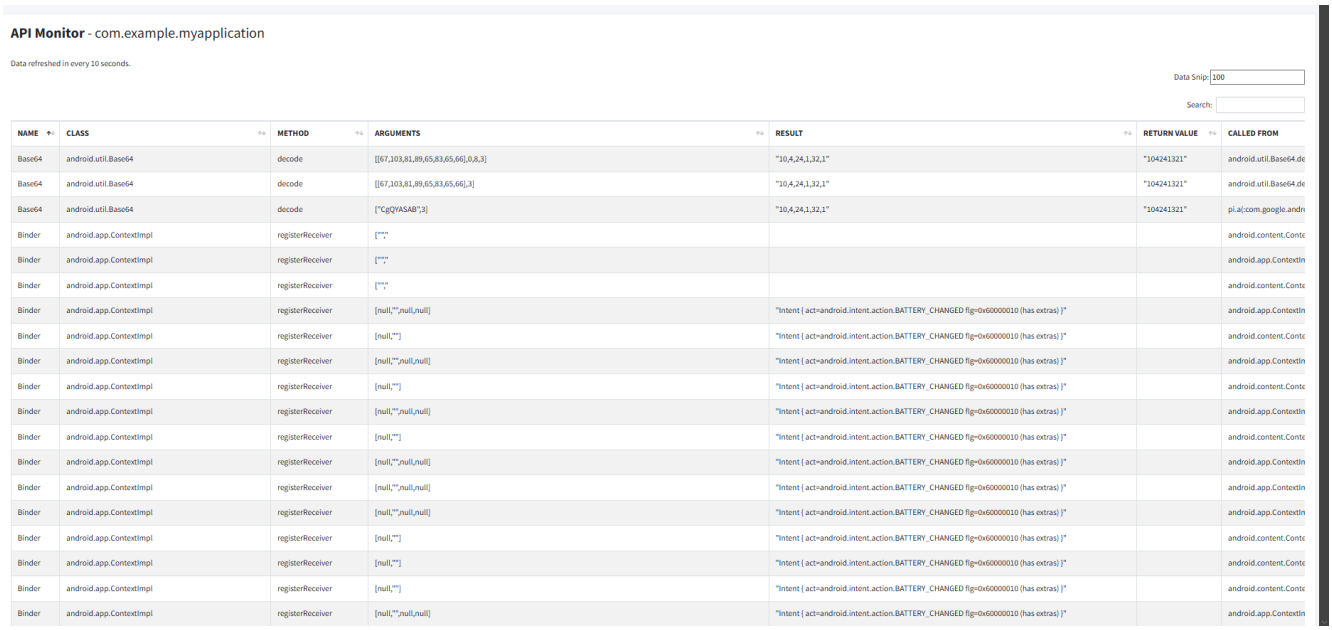



Figura 5. Live API Monitor: Base64.decode y registerReceiver (BATTERY_CHANGED) generados por librerías de Google

# 6. Observaciones informativas y limitaciones

| ID | Observación | Comentario |
|---|---|---|
| O-01 | targetSdk 30 | Versión antigua del SDK; conviene subirla y revisar los cambios de comportamiento. |
| O-02 | Permiso CAMERA solicitado | Aplicar mínimo privilegio si no se usa. |
| O-03 | APKiD: Anti-VM Code y Packer DexGuard | Probablemente de librerías de terceros; no confirmado. |
| O-04 | Sin networkSecurityConfig explícito | Con targetSdk 30 el HTTP en claro está bloqueado por defecto. |
| O-05 | SBOM de 47 paquetes | Sin vulnerabilidades marcadas por MobSF; no se usó un escáner de dependencias dedicado. |

**Limitaciones de las pruebas:**

• **Descompilación incompleta:** el log de MobSF indica que JADX falló en classes.dex y classes5.dex. El resultado vacío de Code Analysis puede subestimar hallazgos en el código propio.

• El análisis dinámico se hizo sobre un APK debug modificado, con pinning XML eliminado.

• El TLS/SSL Security Tester no se ejecutó.

• No se revisó manualmente el código fuente (SQLite, SharedPreferences, archivos, entradas de usuario).

• No se usó OWASP ZAP ni interceptación de tráfico con proxy.

• La cobertura dinámica depende de las acciones realizadas (mapa y marcadores).

• Emulador x86: el comportamiento del GPS y la cámara puede variar en un dispositivo físico.

• Diferencia de puntaje entre escaneos (45/100 con v4.6.2 y 66/100 con v4.6.3) sin explicación en los informes.

## 7. Correcciones propuestas

| Hallazgo | Corrección | Verificación |
|---|---|---|
| V-01, V-02 | Generar keystore propio, configurar signingConfig release con debuggable false, minifyEnabled true. | APK release en MobSF: sin alertas de certificado debug ni debuggable. |
| V-03 | android:allowBackup="false" o exclusiones en backup_rules.xml. | Manifest Analysis sin hallazgo de backup. |
| V-04 | Actualizar profileinstaller o eliminar el receiver con tools:node="remove". | Manifest Analysis sin receiver exportado o riesgo documentado. |
| V-05 | Restringir la clave (paquete + SHA-1 + API), moverla a local.properties, rotarla si se publicó. | Clave fuera del repositorio; uso desde otro paquete rechazado por Google. |
| O-02 | Quitar CAMERA si no se usa; pedir ubicación en tiempo de ejecución. | Permisos mínimos en el informe estático. |
| O-04 | network_security_config con cleartextTrafficPermitted=false. | Network Security en MobSF; TLS Tester ejecutado. |
| General | Cifrado con Android Keystore (AES-GCM), validación de entradas, consultas parametrizadas, targetSdk actualizado. | Nuevo análisis estático y dinámico completo. |

El detalle de implementación con código está en *best_practices.md*.

## 8. Conclusión

El análisis con MobSF identificó 5 hallazgos (2 altos y 3 medios). Los dos altos son propios de una compilación de depuración. En la ejecución no se observaron datos sensibles ni conexiones inseguras confirmadas, pero la descompilación parcial y el TLS Tester sin ejecutar impiden afirmar que la app sea segura. Todos los hallazgos están en estado pendiente. El siguiente paso es aplicar las correcciones, generar el APK release, repetir los análisis y actualizar el estado de cada vulnerabilidad.